# 小米 HyperOS 预装组件数据采集与上报调查报告（公开版）

- 版本：v2
- 日期：2026-11-08
- 分析对象：一台 Xiaomi HyperOS 3.0 设备（具体型号、序列号、SIM 信息已隐去）
- 分析方式：静态反编译 + 运行时数据库取证 + 真机抓包 + 解密验证
- 说明：本文已移除全部个人隐私数据，仅保留技术事实与可复现方法

---

## 0. 摘要

在一台 HyperOS 3.0（Android 16）设备上，确认存在两套运营商终端管理（DM）客户端、一套电信自动注册组件、一套系统遥测组件、一套本地反诈数据库、一套 AI 通话防诈组件，以及系统包管理器的安装上报链路：

| 组件 | 包名 | 归属 | 服务器 | 状态 |
| --- | --- | --- | --- | --- |
| 联通 DM | `com.mobiletools.systemhelper` | 中国联通（Xiaomi 平台签名预装） | `dm.wo.com.cn:18080`（HTTP） | 活跃，周期上报 |
| 移动 DM | `com.miui.dmregservice` | 中国移动 / Richinfo | `a.fxltsbl.com:443`（HTTPS）+ CoAP 5683 | 按需唤醒，心跳正常 |
| 系统遥测 | `com.miui.misightservice` + `/system_ext/bin/misight`(root) | Xiaomi | `event-log.cnbj1.mi-fds.com` | 活跃 |
| 本地反诈库 | `com.miui.securitycenter` | Xiaomi | 未发现上传 | 本地写入 |
| AI 通 | `com.miui.guardprovider` | Xiaomi | `detection-aigc.engine.miui.com` 等 | 开关关闭，未 |

| 组件 | 包名 | 归属 | 服务器 | 状态 |
| --- | --- | --- | --- | --- |
| 话防诈 | | | | 启用 |
| 系统包管理器 | `com.miui.packageinstaller` | Xiaomi | `api.installer.xiaomi.com` / `virus-engine.sec.miui.com` | 活跃，安装/取消均上报 |
| 电信自动注册 | `com.xiaomi.registration` | 中国电信方向（Xiaomi 平台签名预装） | `zzhc.vnet.cn:443`（HTTPS）+ `typdm.tydevice.com:80`（HTTP） | 活跃；偏好项表明曾注册，未捕获该次请求 |

主要结论：

1. `SystemHelper` **默认每 30 分钟调度**采集位置、基站、WiFi 并写入本地队列；**实际上报频率不是 30 分钟**：信号历史默认 **12 小时**一次、App 清单 **24 小时**一次，设备信息由开机/换卡/联网事件触发。实测 R 样本 100 条跨度 55.57 小时，99 个相邻间隔中 83 个恰为 30 分钟，最短 9.4 分钟、最长 300.2 分钟，说明存在中断/额外采样。上报内容包含设备标识、SIM 标识（部分打码）、经纬度（最多 6 位小数）、行政区、基站参数、WiFi 信息、存储信息与 App 使用清单。
2. 上报链路为 **明文 HTTP + AES-128-ECB**，且 **AES key = MD5(明文)**；`sign` 参数是 **RSA(1024 位公钥, MD5)**。对**已有匹配本地明文**的样本可还原网络密文（已实测）；这不能推广为可解密任意未知流量。
3. `DMRegService` 的表结构与代码支持采集 App 清单、SIM 标识、基站/WiFi、按小时流量（含路由器 MAC 与公网 IP）、蓝牙/WiFi 列表，上报开关由云端配置控制；但本次 HTTPS 未解密，字段级上报未确认。公开快照中 `app_info_*` 447 行，`table_name_network` / `table_of_time_related_traffic` / `table_name_wifi_list` / `table_name_bluetooth` / `table_name_battery_charge` 均为 0 行，不能据此证明这些字段本次已采集或已发送。
4. 两套 DM 的导出组件在静态检查中未见调用方校验，存在**潜在未授权调用面**；普通第三方应用的实际可达性与重定向效果尚未用最小 PoC 验证。
5. 截屏时间、安装记录、通话记录仅写入本地反诈库，**未发现上传路径**；AI 通话防诈当前关闭。
6. `com.xiaomi.registration` 是预装的电信终端注册组件，采集 MEID/IMEI/IMSI/ICCID/MAC/Cell ID 等标识

并上报；偏好项与代码表明曾成功注册，基于当前 SIM 与分支条件推断可在移动卡 + WiFi 下完成，未捕获该次请求/响应；导出组件未见调用方校验（静态）。

7. `com.miui.packageinstaller` 打开安装界面即向 `api.installer.xiaomi.com` 发送包名/设备信息；**安装与取消都会**向 `/avl/upload` 上传安装元数据；APK 加密片段/TLSH 是 `cInfo` 控制的代码能力。GuardProvider 云查有服务日志和 DNS/SNI 证据，`/risk/scan` 字段列表为代码级。实测 Avl 风险应用显示“发现风险”并要求单次安装授权，取消仍上传元数据。本次检查时威胁报告目录为空，窗口内未观察到 `/virus/localResult/report`，不证明从未入队；云端命中后的报告仍为代码路径。

---

## 1. 背景

部分小米/HyperOS 机型会随系统预装运营商定制的终端管理（DM）客户端。此类组件通常用于运营商侧的设备注册、网络优化与售后服务，但其数据采集范围、上报频率和加密方式缺少公开说明。

本报告基于一台已 root、已授权 ADB 的自用设备，尝试回答三个问题：

1. 设备上是否存在此类组件？
2. 它们采集什么、发往哪里、如何加密？
3. 用户能否关闭、关闭后是否仍然运行？

---

## 2. 方法

| 步骤 | 工具/手段 |
| --- | --- |
| 组件枚举 | `pm list packages`、`dumpsys package`、`dumpsys alarm`、`dumpsys activity exit-info` |
| 静态分析 | `adb pull` 系统 APK → `jadx` 反编译 → 还原采集/加密/上报逻辑 |
| 证书分析 | `openssl x509` / `openssl rsa` |
| 数据库取证 | 直接读取 `/data/user/0/*/databases/*.db`、`/data/user_de/0/*/databases/*.db` |
| 网络取证 | `tcpdump -i any -w`、`ss -tnp`、`/proc/<pid>/cmdline` 做进程归属 |
| 解密验证 | 依据 `key = MD5(明文)` 重算密钥，与抓包密文逐字节比对，再用 `openssl enc -d -aes-128-ecb` 还 |

| 步骤 | 工具/手段 |
| --- | --- |
| | 原 |
| 触发实验 | 修改采集间隔（已备份并恢复）+ 广播 `BOOT_COMPLETED` 触发上报 |
| 安装器上报验证 | 打开/安装/取消 APK，抓 `logcat` 与 `tcpdump`，核对请求体 |

取证过程未修改业务数据；测试用配置已恢复原值。

---

## 3. 发现一：联通 DM（`com.mobiletools.systemhelper`）

### 3.1 基本信息

| 项 | 值 |
| --- | --- |
| 包名 | `com.mobiletools.systemhelper` |
| APK | `/system/priv-app/SystemHelper/SystemHelper.apk` |
| 版本 | 3.0.1-20260313（versionCode 34，targetSdk 34） |
| UID | 10090 |
| 签名 | Xiaomi MIUI 平台签名（`O=Xiaomi, OU=MIUI, CN=MIUI`） |
| 内置证书 | `assets/pub.cer`，自签名 `O=UNICOM`，RSA 1024 位，序列号 `528B9360`，2019-05-24 → 2119-04-30 |
| 证书指纹 | `SHA256`<br>`81:0C:01:22:BA:6A:F7:A4:B6:A5:92:1F:DB:BB:F9:19:7F:B2:E0:B2:E8:2D:E0:C5:AA:40:D2:8F:1B:7C:65:01` |

### 3.2 采集内容

**信号/位置（默认调度 30 分钟；本地最多 100 条）**

```
Time / IMEI / ICCID / IMSI（部分打码）/ MNC / NetworkType
TAC / CID / PCI / ARFCN / Bands / RSRP / RSRQ / SINR
```

```
LONGITUDE / LATITUDE / District
BSSID / SSID
```

**App 清单（RegType=A）**

每个 App 包含：

```
appLabel / pkgName / runTime / launchCount
tx1 / rx1 / tx2 / rx2 / totalData1 / totalData2 / totalDataWiFi
```

过滤规则：排除 `com.android*`。

在测试设备上，该清单包含系统应用、第三方应用与 root/框架类工具（具体名单已隐去）。这意味着上报内容可用于判断设备是否被 root、安装了哪些工具。

### 3.3 上报协议

```
POST http://dm.wo.com.cn:18080/register?ver=5.0&model=<MODEL>&manuf=<MANUF>&sign=<RSA>
Content-Type: application/encrypted-json
Content-Length: <AES 密文长度>
User-Agent: Dalvik/2.1.0 (Linux; U; Android <VER>; <MODEL> ...)
```

加密流程：

```
key   = MD5(UTF8(plaintext))
body  = AES-128-ECB/PKCS5(plaintext, key)
sign  = Base64(RSA/ECB/PKCS1(pub.cer, key))
```

- `sign` 并非签名，而是 **RSA 包裹后的 AES key**；服务器用私钥解出 MD5 后解密 body。
- AES-ECB 无 IV，确定性加密：相同明文产生相同密文。
- 域名 CNAME：`63ce5fd2be92dcdf.icloudv6.com` → `223.111.128.82`。

### 3.4 队列与重试

- 本地库：`/data/user/0/com.mobiletools.systemhelper/databases/systemhelper`（表 `dmregister`）
- 队列封顶 11 条（按 `count-10` 删除旧记录后再插入）；HTTP 200/416 视为成功，其他状态（含 429）把明文写入队列

- 成功后会启动历史重试线程，弹出最新一条重发；该线程先删除后发送，失败即丢
- 实测队列规模约 10–11 条、约 187 KB，其中单条最大约 66–69 KB

### 3.5 触发条件

```
if (Settings.Secure.getInt("operator_service_improve_plan", 0) != 1) return false;
if (!networkConnected()) return false;
return (isWifi && isChinaMnc) || (!isRoaming && isUnicom);
```

> `isRoaming` 来自 `f1/a.java` 的 `ServiceState.getRoaming()`；`isChinaMnc` 检查 MNC 是否以 460 开头；`isUnicom` 只认 46001/46006/46009/46010。

#### 3.5.1 采集频率 ≠ 上报频率

| 动作 | 周期 | 代码/默认值 |
| --- | --- | --- |
| 信号/位置**采集**（写本地 `signal` 表） | **30 分钟** | `GetsignalInfoInterval = 1800000` |
| 信号历史**上报**（R） | **默认 12 小时** | `signalInfoInterval = 43200000`；首次为随机 init(0–24h) + 12h |
| App 清单**上报**（A） | **24 小时** | `appInfoInterval = 86400000` |
| 调度/设备信息（S） | **24 小时** | `scheduleInterval = 86400000` |
| 设备信息（B/F） | **事件触发** | 开机、换卡、联网、开机后 4 分钟 |
| DMReg 心跳 | 24 小时 | `heartbeat_interval = 86400000` |
| DMReg App 采集 | 7 天 | `app_heartbeat_interval = 604800000` |

> **30 分钟是默认调度，不是严格的实测间隔；也只是“采集到本地”，不是“每 30 分钟上报”。** R 样本 100 条跨度 55.57 小时，83/99 个间隔恰为 30 分钟，最短 9.4 分钟、最长 300.2 分钟。

### 3.6 抓包/解密结果（脱敏）

| 包 | 密文字节 | 响应 | 结果 |
| --- | --- | --- | --- |
| B（设备信息） | 1,024 | 429 | 历史记录为解密成功；本轮未独立复核 |
| R（信号历史） | 68,784 | 429 | **解密成功，100 条记录** |
| A（App 清单） | 40,464 | 200 | 本次未取得匹配明文，未完成恢复；不能据此证明协议不可解密 |
| A（App 清单） | 40,464 | **429** | 旧 ID59 明文 169 项；当前 A 抓包（ID72）未找到匹配明文，未完成逐字节闭环 |

> A 的 200 样本本次没有取得匹配明文；429 的旧 ID59 有 169 项，但当前 A 抓包未找到对应明文，不能替代正文声称的 ID72 闭环。

R 包解密后的统计（不含具体值）：

- 记录数：100
- 跨度 55.57 小时；99 个相邻间隔中 83 个恰为 30 分钟，最短 9.4 分钟、最长 300.2 分钟
- 基站：4 个 CID、3 个 PCI
- WiFi：2 个 SSID
- 经纬度：集中在约 100m × 20m 范围内
- 行政区：单一城区

A 旧 ID59 队列明文的统计（不含具体值；不代表当前抓包已解密）：

- 记录数：169 个 App
- 字段：应用名、包名、使用时长、启动次数、移动/WiFi 收发
- 过滤：排除 `com.android*`
- 同一时段连续请求中，服务器返回 `200` 与 `429` 混合

### 3.7 导出组件：潜在未授权调用面（静态）

| 类型 | 组件 | 风险 |
| --- | --- | --- |
| service | `.service.RegisterHelperService` | AIDL 可改 serverAddress、改间隔、删配置、开关日志 |
| activity | `.Activity.TestActivity` | 打开即显示完整设备信息 JSON |
| receiver | `.control.OnBootReceiver` | 导出；`BOOT_COMPLETED` 是系统受保护广播，普通应用能否触发待验证 |
| receiver | `.control.SIMStateReceiver` | 导出；实际可达性待验证 |
| receiver | `.control.ConnectStateReceiver` | 导出；实际可达性待验证 |

`IRegisterHelperService` 的方法：

```
c(String addr);  // 修改上报服务器
a(int ms);       // 修改采集/上报间隔
e();             // 删除配置
d(boolean on);   // 开关日志
b();             // 读日志开关
```

实现中没有 `getCallingPackage()` 或权限校验，属于静态风险；但绑定服务、启动服务、发送自定义广播与发送受保护广播需要分别验证。`OnBootReceiver` 检查的 `BOOT_COMPLETED` 是系统受保护广播，root/shell 触发不能代替普通应用验证。最小 PoC 尚未完成。

---

## 4. 发现二：移动 DM（`com.miui.dmregservice`）

### 4.1 基本信息

| 项 | 值 |
| --- | --- |
| 包名 | `com.miui.dmregservice` |

| 项 | 值 |
| --- | --- |
| APK | `/product/priv-app/RegService/RegService.apk` |
| 版本 | 15.0.9 |
| UID | 1001（radio） |
| 签名 | Xiaomi MIUI 平台签名 |
| 开发方 | Richinfo（`cn.richinfo.*`） |

### 4.2 数据库

`/data/user_de/0/com.miui.dmregservice/databases/cmcc_dm.db`

| 表 | 内容 |
| --- | --- |
| `app_info_*` | 包名、UID、flags、启动次数、使用时长、移动/WiFi 收发 |
| `table_name_network` | 完整 IMSI、ICCID、cellid、lac、BSSID、SSID、band、RSRP、SINR、运营商 |
| `table_of_time_related_traffic` | 每小时流量、路由器 MAC、公网 IP |
| `table_name_battery_charge` | 电量/温度/状态 |
| `table_name_wifi_list` / `table_name_bluetooth` | WiFi/蓝牙扫描列表 |
| `table_app_collect_list` | 采集窗口与 SIM 标识 |

> 说明：上表是表结构/代码支持的字段，不等于本次已采集或已发送。公开计数中 `app_info_*` 为 447 行，network/traffic/WiFi/Bluetooth/battery 表为 0 行；HTTPS 内容未解密。

预装清单：`key_pre_install_info` 存有约 393 个预装 App 的元数据（名称、包名、版本、安装时间、签名 MD5、flags）；对应上报开关为 N，未确认本次实际上传，也不能据此判断历史上从未上传。

### 4.3 云端开关

| 开关 | 值 |
| --- | --- |
| APP_REPORT_SWITCH | Y |
| key_network_report_switch | Y |
| KEY_TIME_RELATED_TRAFFIC_SWITCH | Y |
| key_wifi_list_report_switch | Y |
| key_bluetooth_report_switch | Y |
| key_heartbeat_switch | Y |
| key_pre_installed_report_switch | N |
| KEY_SANPSHOT_REPORT_SWITCH | N |
| key_battery_charging_report_switch | N |
| key_5g_state_report_switch | N |

周期：心跳 24 小时；App 采集 7 天；24 小时最多 5 次。

### 4.4 网络

- 主通道：`https://a.fxltsbl.com` → `117.134.71.39:443`（TLS）
- 备用：`https://b.fxltsbl.com`
- CoAP/LwM2M：`coap://m.fxltsbl.com:5683` → `117.134.71.81`（本机未观察到流量）
- 实名拍照：`https://auc.fxltsbl.com/AuthCenter/datareport?func=tsdk:photoReg`
- AES key 一部分硬编码于 `Constant.java`（`AES_KEY`），另一部分由 native `libaes-jni` 的 `keyFromJNI()` 提供

### 4.5 运行特征

- 未唤醒时静默（进程被系统回收、无闹钟）
- 收到 `cn.richinfo.dmyk.action.HEARTBEAT` 后立即启动，建立 2 条 TLS 连接，上传约 2.3 KB，收到约 0.3

KB；这里只有 TLS 元数据/连接状态，内容未解密

- `last_success_heartbeat_time` 随之更新，App 采集窗口同步延长

### 4.6 导出组件：潜在未授权调用面（静态）

| 类型 | 组件 | 风险 |
| --- | --- | --- |
| service | `cn.richinfo.dm.service.DMService` | 导出；普通应用 startService 的实际可达性待验证 |
| receiver | `com.richinfo.mthttp.MTStaticBReceiver` | 导出；发送 `alarm_heart`/`alarm_retry` 的实际效果待验证 |
| receiver | `.BootCompleteReceiver` | 导出；受保护广播/普通应用可达性待验证 |

---

## 5. 发现三：系统遥测（MiSight）

| 项 | 值 |
| --- | --- |
| 守护进程 | `/system_ext/bin/misight`（**uid=0 root**） |
| App | `com.miui.misightservice`（0.9.5，`/system_ext/app/MiSightService`） |
| 本地库 | `onetrack` / `one_track_cloud` / `onetrack_cache` |
| 配置/策略 | `https://event-log.cnbj1.mi-fds.com/event-log/...` |
| 上传模式 | `autoupload`，JobScheduler 周期 480 分钟 |
| 采集类别（云端配置） | application / audio_video / bluetooth / camera / cellular / charge / component / display / fingerprint / framework / gps / misight / network 等 |

取证时 `events` 表为空，未观察到大批量数据外发；主要行为是拉取配置与策略。

---

## 6. 发现四：本地反诈库（`com.miui.securitycenter`）

数据库：`/data/misc/user/0/securitycenter/fraud_detection_data.db`

| 表 | 说明 |
| --- | --- |
| `screenshot` | 仅毫秒时间戳（字段名拼写错误 `screenshort_time`） |
| `install_app` | 包名、应用名、来源、版本、MD5、安装完成时间 |
| `fraud_phone` | 号码 MD5、归属地、运营商、时长 |
| `call_forwarding` | 呼叫转移状态 |
| `voip_record` / `screen_share` | 通话/投屏记录 |
| `airplane_mode` / `fraud_url` | 飞行模式/URL 记录 |

- 写入进程：`com.miui.securitycenter.remote`（uid 1000）
- 对外接口：`FraudDetectionProvider`（`exported=true`，signature 权限 `ACCESS_XSOF_FRAUD_DETECTION`）；`MiFraudDetectionService` 为 `exported=false`，仅应用内/系统绑定
- 实测：按一次截屏，`screenshot` 表 +1 行，毫秒时间戳
- **未发现上传路径**：数据写入本地 SQLite，通过 ContentProvider / Binder 在本地暴露；未发现网络 DTO。`fraud-detection.engine.miui.com` 在 SecurityCenter 中仅用于 NFC 反诈配置 GET

---

## 7. 发现五：AI 通话防诈（`com.miui.guardprovider`）

> 一句话：这不是通用录屏工具。**普通未知号码电话只触发语音检测；视频录屏入口是微信/QQ 的特定通话 Activity，并受能力位与摄像头使用状态约束。**视频路径触发后申请整屏镜像，但受 `FLAG_SECURE`/受保护图层限制，敏感界面的实际可录范围未实测。视频检测路径为**每轮录 3 秒 → 上传 → 未命中隔 2 秒再录**。当前开关为 0，未启用。

### 7.0 定位与边界

| 维度 | 范围 |
| --- | --- |
| 触发范围 | 语音检测：普通未知号码电话；视频录屏：`com.tencent.mm`（微信）+ `com.tencent.mobileqq`（QQ）的特定通话 Activity |
| 触发场景 | 语音：电话通话状态；视频：微信/QQ 视频通话 Activity 在前台，且能力位/`isUsingCamera` 满足 |
| 采集范围 | **整屏镜像**（`AUTO_MIRROR` + 全屏尺寸）；未设置 `FLAG_SECURE`，安全窗口/受保护图层通常不会被捕获，实际范围未实测 |
| 产物 | 每段 3 秒的 `clip.mp4` → Base64 → 上传 `detection-aigc.engine.miui.com` |
| 分析版本 | 预装 `2.5.6-20251106.0`；当前设备已更新到 `3.1.4-20260902.0`，3 秒循环与上传链路在 3.1.4 中仍存在。3.1.4 APK SHA-256：`eff2c614d054263068e931f859f2e9fb4c66e31f960d815ab507abbdff15bb5d`（本地 `private/apk/`）；关键类 `re3/x7/k43/u23` 已入库 |
| 当前状态 | 开关 0、`RECORD_AUDIO` 未授权、无活跃 projection、无 clip 文件 |

### 7.1 录屏与上传链路

- `p079l1/d.java`：反射 `MediaProjectionManager.mService` → 直接 `createProjection`，绕过系统授权对话框
- `p079l1/a.java`：
- `createVirtualDisplay("ScreenRecorder", 整屏宽, 整屏高, dpi, 16, ...)`
- `16` = `VIRTUAL_DISPLAY_FLAG_AUTO_MIRROR`；未设置 `VIRTUAL_DISPLAY_FLAG_SECURE`（4），因此安全窗口内容通常不会被捕获
- `MediaRecorder` 720×1280 / 24fps / 1Mbps；每次录制 3 秒（见 §7.1.1）
- 临时文件 `cache/clip_*`
- `AiGuardService.C(Path)`：
- `Files.readAllBytes` → Base64
- JSON：`{"streamName":"clip.mp4","fileBase64":"...","requestId":"..."}`
- 经 `com.miui.securitycenter.confidentialcomputing` 加密为 `EncryptedData`

- `POST https://detection-aigc.engine.miui.com/aiVideo/pcc/detection`
- 上传后 `Files.delete(path)`（成功失败都删）
- 音频文本走另一条：`POST /ai/audio/text/pcc/detection`

### 7.1.1 视频检测循环：录 3 秒 → 上传 → 未命中隔 2 秒 → 再录

`AiGuardService$p.A`（`COMMAND=2` 视频检测协程）是一个 `while (scope.isActive)` 循环：

```
// 由反编译控制流还原的伪代码，不是原始 Kotlin 源码
while (scope.isActive) {
    recorder.c()                // MediaRecorder.start()
    delay(3.seconds)            // U3.c.o(3, SECONDS)
    val clip = recorder.d()     // MediaRecorder.stop()，返回 cache/clip_*
    if (clip == null) continue  // 空 clip 直接重试，不进入 2 秒等待
    val hit = C(clip)           // Base64 → 加密 → POST /aiVideo/pcc/detection
    if (hit) {                  // checkRes == true
        u(scene)                // 弹警告
        stopSelf()
        break
    }
    Files.delete(clip)          // 未命中，删除
    delay(2.seconds)            // U3.c.o(2, SECONDS)
}
recorder.b()                    // MediaRecorder.release()
```

- `3` 和 `2` 是方法内硬编码常量（`r6=3`、`r7=2`），不来自云端配置。
- 实际周期 = 3 秒录制 + 上传/等待云端响应 + 2 秒间隔，不是严格的“每 3 秒一次”。
- 命中后弹警告并 `stopSelf()`；未命中删除 `clip`，等 2 秒后继续。
- 若录制返回空（例如 `stop()` 失败），直接重试，不进入 2 秒等待。
- 单次服务生命周期由云端配置 `detectionServiceLifetimeThresholdInMinutes` 限制，默认 10 分钟；通话结束或服务停止时协程取消。
- 该循环只在 `COMMAND=2`（视频检测）路径；`COMMAND=1`（语音）走 ASR 文本检测，不使用这段录屏循环。
- `2.5.6-20251106.0` 与当前 `3.1.4-20260902.0` 的静态控制流均支持该循环；3.1.4 对应 `defpackage.x7.o`。默认反编译失败；本轮用 `--show-bad-code --comments-level debug` 取得指令级伪代码，工具仍因

RegionMakerVisitor 的 StackOverflowError 返回 3，不是成功恢复的结构化 Java。带 APK 哈希/命令的转储节选见 evidence/decompiled/key/MIUIGuardProvider/defpackage/x7_o.debug.txt，原 x7.java 占位体保留。该证据不代表已实测录屏上传。

- 3.1.4 中对应类：defpackage.re3（录制）、defpackage.x7（循环）、defpackage.k43（检测接口）、defpackage.u23（投屏）。

> 取证说明：JADX 默认模式在 AiGuardService$p.A 抛 JadxOverflowException，方法体被标记为 “not decompiled”。改用 jadx --show-bad-code --comments-level debug 重反编译后取得上述 smali 伪代码；U3.c.o(n, SECONDS) 与 V3.W.b(...)（Kotlin delay）已交叉确认。此前“录制类无可见调用点”的表述据此撤回。

因为 AUTO_MIRROR + 整屏尺寸，视频路径申请的是整屏镜像，不是“只录微信”；但未设置 FLAG_SECURE，银行/密码等安全窗口与受保护图层的实际可录范围未实测，不能断言“任何界面必然被录入”。

### 7.2 触发链

```
SecurityCenter AiGuardSceneService
  ├── 监听 miui.media.AUDIO_VOIP_RECORD_STATE_CHANGED_ACTION
  ├── TelephonyManager 通话状态（普通电话）
  ├── 监听前台 Activity（IProcessObserver）
  |     ├── com.tencent.mm.plugin.voip.ui.VideoActivity   → 微信
  |     └── com.tencent.av.ui.AVActivity                  → QQ
  └── startForegroundService(com.miui.guardprovider/.aiguard.AiGuardService)
        COMMAND=1  PHONE_SCAM_SCENE=<scene>  CAPABILITIES=<bits>
        COMMAND=2  VIDEO_SCAM_SCENE=<scene>  CAPABILITIES=<bits>
```

- 微信/QQ 路径：com.tencent.mm、com.tencent.mobileqq，匹配对应 Activity
- **普通电话路径**：TelephonyManager 通话状态；CALL_STATE=2 且号码**不在联系人、也不在黄页**时，启动 PHONE_SCAM_SCENE=2，走 COMMAND=1 语音检测；**不进入这段录屏循环**
- 场景值：QQ {3,1}，微信 {4,2}
- CAPABILITIES & 1 → 语音检测；CAPABILITIES & 2 且 isUsingCamera → 视频检测
- AiGuardService.onStartCommand：
- COMMAND=3：只同步 ai_guard_function_switch
- COMMAND=1：语音检测，要求 RECORD_AUDIO

- `COMMAND=2`：视频检测 → `P(scene)` → `p.A` 3 秒循环 → 每段 `C(Path)` 上传

### 7.3 三种“看屏幕”不是同一件事

| 功能 | 触发范围 | 采集范围 | 存什么 |
| --- | --- | --- | --- |
| AI 防诈录屏 | **微信/QQ 视频通话**（普通电话只走语音） | **整屏可捕获画面**（受 `FLAG_SECURE` 限制） | `clip.mp4` 上传 |
| 截屏记录 | 任何 App（用户截屏） | 仅事件 | 毫秒时间戳 |
| 屏幕共享记录 | 任何 App（除忽略名单） | 仅包名 | 包名 + 起止 + 时长 |

### 7.4 局限性

1. **视频触发面有限**：录屏入口是微信/QQ 的特定通话 Activity；普通未知号码电话只触发语音检测；Telegram、WhatsApp、Signal、钉钉、飞书等不在列表。
2. **依赖特定 Activity**：微信 `com.tencent.mm.plugin.voip.ui.VideoActivity`、QQ `com.tencent.av.ui.AVActivity`；版本更新、小窗、分屏、悬浮窗都可能导致匹配失败。
3. **视频依赖 `isUsingCamera`**：纯语音通话只走音频检测，不触发视频录制。
4. **`RECORD_AUDIO` 只约束语音路径**：`COMMAND=1` 在权限被撤销时打印 "permissions revoked" 并跳过；`COMMAND=2` 视频路径不检查该运行时权限，依赖 `MediaProjection` 与 `CAPTURE_VIDEO_OUTPUT`。
5. **依赖 `CAPABILITIES` 位**：bit1 语音、bit2 视频，由云端配置下发；位不满足就不启动。
6. **依赖云端开关**：`ai_guard_function_available` 与 `ai_guard_function_switch` 任一不满足都不会启动。
7. **3 秒/2 秒是硬编码节奏**：每轮固定录 3 秒，未命中后固定等 2 秒；上传与云端响应时间会拉长实际周期。视频路径已确认接线，调用点为 `AiGuardService$p.A`（见 §7.1.1）。
8. **全屏镜像的边界**：视频路径申请整屏镜像，可能采集切换后其他应用的可捕获画面；但受 `FLAG_SECURE`、受保护图层与系统实现限制，银行/密码等敏感界面的实际可录范围未验证。
9. **只在通话期间**：不是 7×24 录屏；通话结束即停止。
10. **自身录屏不进 `screen_share`**：`com.miui.guardprovider` 在忽略名单里，安全中心不会记录它自己的录屏。
11. **音频冲突/过热**：代码有音频冲突时停止的日志；过热中断未在代码中确认。
12. **不可见性**：录屏与上传没有用户可见确认；Android 14+ 可能显示隐私指示器，但授权对话框被绕过。

### 7.5 当前运行状态

| 检查项 | 结果 |
| --- | --- |
| `ai_guard_function_switch` | 0 |
| `ai_guard_function_available` | false |
| `RECORD_AUDIO`（仅语音路径） | granted=false |
| 活跃 MediaProjection | null |
| `cache/clip_*` | 无 |
| `ai_guard_daily_report.xml` | `<map />`（空） |
| `screen_share` / `voip_record` | 0 行 |

> 当前设备为 `3.1.4-20260902.0`；上表已在 3.1.4 上复核；`available` 来自 SecurityCenter 的 `ai_guard_function_cloud_data.xml`。
>
> 视频路径不检查 `RECORD_AUDIO`；当前未启用的决定性条件是 `ai_guard_function_switch=0`、`available=false`、无活跃 `MediaProjection`、无 `clip` 文件。
>
> 结论：**能力存在，且视频路径已确认接线（3 秒一段、未命中隔 2 秒再录）；触发面窄、依赖多、当前未启用；视频路径申请整屏镜像，但受 `FLAG_SECURE`/受保护图层限制，敏感界面的实际可录范围未实测。**

---

## 8. 发现六：中国电信自动注册组件（`com.xiaomi.registration`）

> 一句话：这是小米预装的电信终端注册组件，平台签名、与电话应用共享 UID。它**不上传 App 清单**，采集 MEID/IMEI/IMSI/ICCID/MAC/Cell ID 等标识并上报；偏好项与代码表明曾成功注册，基于当前 SIM 与分支条件推断可在移动卡 + WiFi 下完成，未捕获该次请求/响应。

### 8.1 基本信息

| 项 | 值 |
| --- | --- |
| 包名 / APK | `com.xiaomi.registration` / `/product/priv-app/AutoRegistration/AutoRegistration.apk` |
| 版本 | 15.1.22（versionCode 63，targetSdk 34） |
| 签名 / UID | Xiaomi MIUI 平台签名 / **1001** **`android.uid.phone`** |
| 进程 / 状态 | `radio`；`RegistrationService` 活跃；12 小时闹钟已挂 |
| APK SHA-256 | `91f6324b07fe67cb753ac2875dd0c59f2b8cb9a43b97d92fb42b11b85f27c303` |

Manifest 声明 16 个权限；因共享电话 UID，实际继承 `READ_SMS`、`READ_CALL_LOG`、`CALL_PHONE`、`CAMERA`、`WRITE_CONTACTS` 等。代码实际使用：

- `getImeiForSlot` / `getMeid`
- `getSubscriberId` / `getIccId`
- `WifiManager.getConnectionInfo`（MAC/BSSID）
- `CellInfo`（Cell ID/TAC）
- `SmsManager.sendDataMessage`（`10659401`）

未发现读取短信收件箱、通话记录、联系人或相机的代码。

### 8.2 注册分支与发送方式

顶层在 A/B 之间二选一；C 是选中 A 后初始化的短信注册机制，不是与 A/B 平级的第三个分支。

| 路径 | 地址 | 传输 | 本机证据 |
| --- | --- | --- | --- |
| A | `https://zzhc.vnet.cn` | HTTPS；body 为 Base64(JSON) | 偏好项与代码表明曾注册，未捕获该次请求/响应 |
| B | `http://typdm.tydevice.com?jsonstr=...` | HTTP 明文；JSON 在 URL | 未实际触发 |

| 路径 | 地址 | 传输 | 本机证据 |
| --- | --- | --- | --- |
| C | 短信 `10659401` | 二进制短信，明文 | 未实际触发 |

**A/B 选择条件**（属性读取与 `k1.d.d()` 展开后的等价表达）：

```
z2 = (ro.radio.noril && ro.ril.oem.ctei 非空)
     || (Build.DEVICE in {ruan, koto, organ} && !Build.IS_CT_CUSTOMIZATION)


z2 == true  → B (typdm)
z2 == false → A (zzhc)
```

其中 `ro.radio.noril` 按布尔属性读取（默认 false），表示无常规蜂窝 RIL；`ro.ril.oem.ctei` 是 OEM 写入的电信终端标识；`Build.IS_CT_CUSTOMIZATION` 是电信定制版标志。满足“无 RIL 且 CTEI 非空”，或命中下列代号且为非电信定制版时，选择 B；否则选择 A。这是分支选择，不是安全校验。本机 `z2=false`，选择 A。

| 代号 | 机型 |
| --- | --- |
| `ruan` | Redmi Pad Pro 5G / POCO Pad 5G |
| `koto` | Redmi Pad 2 4G |
| `organ` | Redmi Pad 2 Pro 5G |

**A 的实际发送条件**：分支选择不等于立即发送，还受 `i1/p.java` 的运行时条件限制：

- 任一 SIM 就绪、非漫游、`device_provisioned=1`；
- SIM ICCID 变化、周期触发、系统版本变化、5G 开关变化或默认数据卡变化；
- 若当前是蜂窝网络且默认数据卡不是电信卡，则跳过；WiFi 下放行；
- 满足后由 `p` 调度 `RegistrationJobService`，走 `zzhc`。

**C 与 A 的关系**：`p` 构造函数创建 `j[]`，因此选 B 时不初始化 C；选 A 时，短信注册可与 HTTPS 注册并存，但受电信卡、IMS 能力、在途注册 ID 等条件限制。ICCID 需以 `898603`/`898611`/`898612` 开头；本机为移动卡 `898602…`，未触发 C。

**发送链路与协议定位**（字段清单统一见 §8.3）：

| 路径 | 代码链路 | 协议细节 |
| --- | --- | --- |
| A | `i1/p.java` → `RegistrationJobService` → `i1/l.java` → `i1/m.java` case 0 | 按 `post_params.xml` 收集；`resultCode == "0"` 视为成功；Header 写 `encrypted-json`，但载荷仅 Base64 编码，没有 AES/RSA |
| B | `j1/c.java` → `j1/b.java` → `i1/m.java` case 1 | JSON 放入 URL 的 `jsonstr` 参数，走明文 HTTP |
| C | `i1/j.java` → `i1/q.java` → `i1/w.java` | XML 载荷经二进制短信发送 |

### 8.3 采集字段

路径 A（`post_params.xml`）：

```
REGVER / MEID / MODEL / SWVER
SIM1CDMAIMSI / SIM2CDMAIMSI / UETYPE
SIM1ICCID / SIM2ICCID
SIM1LTEIMSI / SIM2LTEIMSI
MACID / OSVER / REGDATE
IMEI1 / IMEI2 / DATASIM
RAM / ROM
SIM1CELLID / SIM2CELLID
FIVEGSW1 / FIVEGSW2
NWTYPE1 / NWTYPE2 / ACCESSTYPE / 5GRCSSW
SSW1 / SSW2
CARD1TYPE / CARD2TYPE
POWER
TAC1 / TAC2
```

路径 B：`VER / CTEI / MAC / IP / UPLINKMAC / LINK / FWVER / DATE`。这是 B 自身的字段，不表示在 A 的字段上追加。

路径 C 的 XML 字段：

```
<a><b>型号</b><c>IMEI1</c><d>IMEI2</d><e>IMSI</e><f>系统版本</f><g>卡槽/网络</g></a>
```

### 8.4 触发与本机状态

触发：开机、`PROVISION_COMPLETE`、`SIM_STATE_CHANGED`、`CONNECTIVITY_CHANGE/SERVICE_STATE`、两个 12 小时闹钟、

`*#*#9999#*#*`；WiFi 下非电信卡也允许路径 A。

本机：

```
radio 4460 ... com.xiaomi.registration
com.xiaomi.registration/.autoregistration.RegistrationService
*walarm*:...SMS_AUTO_REGISTRATION_PERIOD_TRIGGER  (12h)
*walarm*:...AUTO_REGISTRATION_PERIOD_TRIGGER      (12h)
```

SharedPreferences：

```
<map>
  <string name="pref_meid">&lt;MEID&gt;</string>
  <string name="sim_iccid">&lt;ICCID，前 6 位 898602&gt;</string>
  <string name="register_regtime">2026-10-31 12:09:53</string>
  <string name="register_sw_version">&lt;系统版本&gt;</string>
  <int name="register_dds_slot" value="0" />
  <string name="autosms_provision">true</string>
</map>
```

`register_regtime` 有值，且同时有 `register_dds_slot` / `register_sw_version`，对应 `AutoRegReceiver` 的成功分支（路径 A）。`sim_iccid` 前 6 位 `898602` 是中国移动，因此**推断**注册时可在移动卡 + WiFi 下完成；但未捕获该次请求/响应，历史 SIM/网络条件不能由当前快照独立证明。

### 8.5 问题与建议

| # | 问题 |
| --- | --- |
| 1 | **跨运营商**：WiFi 下非电信卡也向 `zzhc.vnet.cn` 注册 |
| 2 | **持久标识**：IMEI/MEID + IMSI/ICCID 可跨卡追踪设备 |
| 3 | **位置推断**：Cell ID/TAC + BSSID 可推断粗略位置 |
| 4 | **权限很大**：共享电话 UID，继承短信/通话记录/相机/联系人 |
| 5 | **入口开放（静态）**：`AutoRegReceiver` / `RegistrationService` 导出且未见调用方校验；普通应用实际可达性待 PoC |
| 6 | **明文 HTTP**：路径 B 在满足条件的机型上明文发送 MAC/IP/BSSID/CTEI |

| # | 问题 |
|---|---|

7 **Header 与载荷不符**：Header 写 `encrypted-json`，实际只是 Base64 编码

**用户侧**：不用电信卡时，可考虑 `adb shell pm disable-user --user 0 com.xiaomi.registration`，但可能影响电信 VoLTE/5G/IMS；或封堵 `zzhc.vnet.cn` / `typdm.tydevice.com`。

**厂商/运营商侧**：路径 B 改 HTTPS；给导出组件加签名权限或调用方校验；非电信卡明确提示或停止注册；提供用户开关与数据清单。

### 8.6 局限与证据

局限：

1. 未对 `zzhc.vnet.cn` 抓 TLS，POST body 为代码层推断。
2. “注册成功”由 `register_regtime` 与成功分支推断，未捕获服务器响应。
3. 路径 B/C 在本机未实际触发。
4. 基于单台设备、单版本 15.1.22；未评估禁用对电信 VoLTE/5G 的影响。

证据：

```
/product/priv-app/AutoRegistration/AutoRegistration.apk
/data/user_de/0/com.xiaomi.registration/shared_prefs/...
i1/{p,j,q,w,l,m}.java
j1/{b,c}.java
k1/{a,c,d}.java
com/xiaomi/registration/autoregistration/{AutoRegReceiver,RegistrationService,RegistrationJobService}.java
res/xml/post_params.xml
AndroidManifest.xml
```

上述关键类已加入 `evidence/decompiled/key/AutoRegistration/`。同目录 `AndroidManifest.xml` 由 JADX 1.5.6 对上述 SHA-256 的 APK 执行 `jadx --config none --no-src -d <out> evidence/apk/AutoRegistration.apk` 解码取得；Manifest 显示 `RegistrationService`/`AutoRegReceiver` 导出且未声明权限，`RegistrationJobService` 则受 `BIND_JOB_SERVICE` 保护，不能混同。现有完整源码树 `evidence/decompiled/full/AutoRegistration/` 仅本地保留，先前资源目录为空；公开 Manifest 是此次独立补充，不宣称原完整树已包含资源。

## 9. 发现七：系统包管理器安装上报

### 9.1 基本信息

| 项 | 值 |
| --- | --- |
| 包名 | `com.miui.packageinstaller` |
| 版本 | 5.5.7.0.0-20261012（versionCode 55700） |
| 关联组件 | `com.miui.guardprovider` 3.1.4-20260902.0 |
| 入口 | 文件管理器 `ACTION_VIEW` → `NewInstallerPrepareActivity` |
| 服务器 | `api.installer.xiaomi.com`、`virus-engine.sec.miui.com`、`*.a.market.xiaomi.com` |
| 适用边界 | 以下已确认上报来自 MIUI 安装器 UI。本次两条 `adb install` / `pm install` 测试未进入该 UI，窗口内未观察到 `/avl/upload`，不排除其他或后续链路 |

### 9.2 结论

| # | 结论 | 证据级别 |
| --- | --- | --- |
| 1 | 打开安装界面即向 `api.installer.xiaomi.com` 发送包名、应用名、安装来源、OAID、机型、区域、系统版本、网络类型、APK MD5/签名等，并请求 `/v3/cloud_config/query`、`/v4/game/interceptcheck/safemode`、`/info/layout/v2` | 实测 |
| 2 | 点“安装”和点“取消”都会向 `/avl/upload` 上传安装元数据：`installCnt=1/0`，字段含包名、应用名、版本、APK MD5、签名、大小、全部权限、来源、渠道 MD5 | 实测 |
| 3 | 风险应用会被 GuardProvider 的 Avl 等引擎标记（实测 `Risk/Android.R_Cont.Porn`，level=1）；安装器显示“发现风险”，要求“单次安装授权”+身份验证；取消和授权后安装成功都会上传元数据 | 实测 |
| 4 | 安装前 GuardProvider 云查 `/risk/scan`（3.1.4；2.5.6 为 `/virus/scan`），字段含包 | 实测（服务日志 + DNS/SNI）；字段 |

| # | 结论 | 证据级别 |
| --- | --- | --- |
| | 名、版本、证书 MD5/SHA-256、manifest SHA-256 | 列表为代码级 |
| 5 | 云端 per-app 配置返回 `riskType`、`registrationStatus`、`registrationRestrictStatus`、`installNotAllow`、`areaForbiddenInstall`、`rc`、`cInfo`，决定未备案/风险提示、禁止安装和取片指令；全局配置还含 16 条禁装规则、94 个包的离线安装白名单、`oneClick` 授权参数 | per-app：实测（日志）+ 代码；全局配置：实测（只读响应） |
| 6 | 云端可要求上传 APK 片段/TLSH：`cInfo.cFlag` → `cToken`（AES/CBC/PKCS5，key/IV 来自 `libxiaomiSafe.so`）+ `cOffset/cSize/cMd5`；`tFlag` → TLSH `tInfo` | 代码；本次未触发 |
| 7 | 云端威胁命中后的 `/virus/localResult/report` 代码路径包含威胁名/等级、包信息、证书、APK 哈希、MIUI/Android/设备、UUID、`hitFiles`；3.1.4 用 `ReportStore`，2.5.6 用 `ReportWorker`。本次本地 Avl level=1 命中后检查目录为空，测试窗口内未观察到报告请求，不能证明从未生成文件 | 代码 + 有限窗口观察 |
| 8 | 安装完成会向本地反诈库 `content://com.xiaomi.security.xsof.FraudDetectionProvider/install_app` 写入 `pkg_name/app_name/install_finish_time/app_tag_id/version_code` | 代码/本地语义 |
| 9 | 本次 `adb install` / `pm install` 安装成功，未进入 MIUI 安装器 UI，测试窗口内未观察到 `/avl/upload`；不能排除其他后台或延迟链路 | 实测（本次路径/窗口） |
| 10 | 风险提示页同时展示第三方应用推荐广告，资源来自 `*.a.market.xiaomi.com` | 实测 |

## 9.3 关键细节

### 9.3.1 三个时点

- **打开安装界面（用户尚未点“安装”）**：安装器向 `api.installer.xiaomi.com` 发送包名、应用名、安装来源、OAID、机型、区域、系统版本、网络类型，并请求 `/v3/cloud_config/query`（全局配置）、`/v4/game/interceptcheck/safemode`（按包配置，按安装模式也可能是 `normal`/`enhancemode`；含 APK 签名/MD5/`antifraudLabel` 等）、`/info/layout/v2`（布局/广告）。
- **点“安装”或“取消”**：都向 `/avl/upload` POST JSON；`installCnt=1` 表示安装，`0` 表示取消；服务器

返回 `{"data":"succ","code":200}`。也就是说，**“取消”不是无痕操作**。

- **风险应用**：GuardProvider 的 Avl 引擎命中后，安装器显示“发现风险”和“单次安装授权”；取消和授权后安装成功都会上传上述元数据，但 `/avl/upload` 中不带威胁名或扫描结果。

### 9.3.2 `/avl/upload` 字段

| 字段 | 含义 | 备注 |
| --- | --- | --- |
| `packageName` / `name` | 包名 / 应用名 | 安装器解析 APK 得到 |
| `versionCode` / `versionName` | 版本号 / 版本名 | 便于识别具体版本 |
| `apkHash` | APK 文件 MD5 | 可用于样本匹配 |
| `fingerprint` | 签名摘要 | 与证书/签名关联 |
| `apkSize` | APK 大小 | 辅助指纹 |
| `permission` | 申请的全部权限 | 逗号连接，可能很长 |
| `appSourcepackageName` / `appSourceValue` | 安装来源包名 / 标签 | 如文件管理器 |
| `cdMd5` | 渠道包摘要 | 渠道识别 |
| `installTime` / `installCnt` / `touchInstallCnt` | 上报时生成的时间戳 / 安装或取消 / 点击计数 | 取消时也会生成，不证明安装完成 |
| `apkPath` | 调用方提供的路径 | 可能为空 |
| `cToken` / `cOffset` / `cSize` / `cMd5` | 云端要求的 APK 加密片段 | 仅 `cInfo.cFlag=true` 时 |
| `tInfo` / `tFlag` | TLSH 模糊哈希 / 开关 | 仅 `tFlag=true` 时 |

### 9.3.3 云端配置与安装决策

**per-app 配置**（`/v4/game/interceptcheck/{normal,enhancemode,safemode}`，按安装模式选择；风险样本走 `safemode`）：

| 字段 | 作用 |
| --- | --- |
| `riskType` / `sourceRiskType` | 云端风险分类；风险样本实测 `9999` |

| 字段 | 作用 |
| --- | --- |
| `registrationStatus` | `1=未备案`、`2=已备案`、`3=无需备案` |
| `registrationRestrictStatus` | `1` 时禁止安装 |
| `installNotAllow` | `true` 时禁止安装 |
| `areaForbiddenInstall` | 地区禁装 |
| `strategyLevel` | 风险策略等级 |
| `riskWarningTip` / `riskDetailTip` / `securityTip` | 风险提示文案 |
| `rc` | 安装频率/身份验证策略（如 24 小时内第 N 次安装要求验证） |
| `cInfo` | APK 片段/TLSH 上传指令 |

**全局配置**（`/v3/cloud_config/query`，实测约 44 KB）：

| 字段 | 实测内容 |
| --- | --- |
| `forbiddenList` | 16 条包/版本禁装规则 |
| `offlineInstallAppSignList` | 94 个包的 APK 哈希白名单 |
| `trustedSourcePackages` | 1 个受信任安装来源 |
| `unknownSourceAuthAskWhitelist` | 1 个未知来源授权白名单包 |
| `oneClick` | `authTimeout=1500`、`preValidationSwitch=0`、`authRollbackSwitch=0`、`apkParseTimeout=500`、98 个 partner 公钥 |
| `exitPageText` | 与实测取消页一致：`已取消安装` / `去应用商店发现更多心动应用与游戏` |
| `commonConfig.enableDefaultSafeMode` | 1 |
| `improveEfficiencyAppList` | 7 个限时推荐包（时间窗已过期） |

本次 16 条禁装规则中，15 条是旧版 AOSP/Google 包安装器（`com.android.packageinstaller` 9–16、

`com.google.android.packageinstaller` 9/10/11 的特定 build），另 1 条是 `com.xiaomi.xmsf` 7.1.7-C。安装器按 `packageName + versionName` 精确匹配，命中后进入阻止安装分支。

这些是云端下发的安装策略，不是上报；完整包名/哈希/公钥列表只在本地 `private/frida/`。per-app `CloudParams` 的完整响应本次未捕获，`riskType=9999`/`regS=1` 来自安装器日志与代码级证据。

### 9.3.4 风险应用与单次安装授权

- 云端把风险样本标为“未备案、未禁止安装”：`regS=[1]`、`regRS=[0]`、`riskType=9999`、`app_manage_scene=off_shelf`。
- GuardProvider 的 Avl 引擎返回 `Risk/Android.R_Cont.Porn`（threatLevel=1，`forbidden=false`）；安装器显示“发现风险”“安装该应用存在高风险”，随后要求“单次安装授权”并做身份验证。
- 在风险提示页取消：`/avl/upload` 发送 `installCnt=0`；完成单次安装授权并安装成功：发送 `installCnt=1`，`lastUpdateTime` 更新。两次请求都包含完整应用元数据，均不含威胁名/扫描结果，也未出现 `cToken/tInfo`。
- 本地 Avl level=1 命中后检查 `ReportStore` 目录为空，测试窗口内未观察到威胁报告请求；不能排除文件曾生成后上传或删除，威胁报告路径仍按代码级记录。

### 9.3.5 GuardProvider 云查与威胁报告

- 包管理器构造 `ScanRequestArgs.Builder(1)`（安装场景），默认 `useCloudScan=true`；GuardProvider 向 `https://virus-engine.sec.miui.com/risk/scan`（3.1.4；2.5.6 为 `/virus/scan`）发送 `CloudScanApkInfo`：包名、版本、证书 MD5、证书 SHA-256、manifest SHA-256。
- 云端威胁命中后的 `/virus/localResult/report`：3.1.4 使用 `ReportStore`（写 `files/upload/` 后上传），2.5.6 使用 WorkManager `ReportWorker`（约 2 小时延迟）。字段包括威胁等级/名称、恶意代码特征、包信息、证书、APK MD5/SHA-256、MIUI/Android/设备、UUID、`hitFiles`。
- 本次本地 Avl 一级命中后检查目录为空，窗口内未观察到上述报告请求；不能仅凭事后空目录判断是否曾入队，也不能证明每次扫描都上报或都不上报。

### 9.3.6 APK 片段 / TLSH 能力

- `cInfo.cFlag=true` 时，安装器读取 `[cOffset, cOffset+cSize)`，用 AES/CBC/PKCS5 加密后 Base64 写入 `cToken`，并上传 `cOffset`、`cSize`、`cMd5`；密钥为 `MD5(XiaoMiSafe.getKeyBytes())`，IV 来自 `XiaoMiSafe.getKeyViBytes()`。

- `tFlag=true` 时计算 APK 的 TLSH 模糊哈希，写入 `tInfo`。
- 默认不上传整包；但 `cOffset/cSize` 由服务器决定，若 `cSize` 设为整个文件大小，等价于上传整包。该能力可用于完整性校验，也意味着服务器可按需取走 APK 任意片段。本次未触发。

### 9.3.7 本地反诈与广告

- 安装完成后，安装器向 `content://com.xiaomi.security.xsof.FraudDetectionProvider/install_app` 插入 `pkg_name`、`app_name`、`install_finish_time`、`app_tag_id`、`version_code`；这是本地 SecurityCenter 反诈库，未发现该 Provider 直接上传。
- 风险提示页下方同时展示“您可能还喜欢 / 广告”第三方应用推荐，资源来自 `t1.a.market.xiaomi.com` / `t5.a.market.xiaomi.com`。安全警告与广告同屏，是一个值得记录的产品行为。

### 9.3.8 边界：shell 安装

- 本次 `adb install` / `pm install` 均安装成功，未进入 MIUI 安装器准备界面，测试窗口内未观察到 `/avl/upload`；本次进程检查中 `adb install` 只见包变更处理进程，`pm install` 未见安装器进程，不作为长期行为证明。
- 因此，已确认的上报/风险提示来自 MIUI 安装器 UI 路径；本次两条 shell 安装路径在观察窗口内未出现同一 UI `/avl/upload` 上报，不推广到所有 shell 安装、后续后台组件或延迟上报。

## 9.4 隐私与安全影响

- **可关联的安装画像**：包名、应用名、版本、APK MD5、签名、大小、权限、来源、渠道、时间与 OAID/机型组合，可长期关联同一设备的安装历史和应用偏好；取消安装也会留下“曾打算安装”的记录。
- **云端可控的取片能力**：`cOffset/cSize` 由服务器决定，意味着服务器可按需取走 APK 任意区间；虽然默认只传元数据，但用户无法从界面得知或拒绝。
- **威胁报告的路径风险**：`hitFiles` 可能包含用户文件路径；设备名、UUID 与包信息组合后可进一步关联设备。
- **风险提示与广告同屏**：安全警告下方展示第三方应用推荐，容易分散用户对风险的注意，也存在利益冲突。
- **安装方式存在观察差异**：本次 MIUI 安装器 UI 测试有上报；两条 `adb install`/`pm install` 测试在窗口内未观察到同一 UI `/avl/upload`，不代表设备层面无其他或后续上报。

- **缺少知情与选择**：没有用户可见的上传范围说明、云端取片提示或威胁报告记录入口。

### 9.5 主要问题

| # | 问题 |
| --- | --- |
| 1 | **取消也上传**：用户没有安装，安装记录仍被上报 |
| 2 | **打开即上报**：尚未确认安装，包名/应用名/设备信息已发出 |
| 3 | **字段过宽**：应用名、版本、签名、APK MD5、大小、全部权限、安装来源 |
| 4 | **云端可控取片**：`cOffset/cSize` 由服务器决定，可读取 APK 任意区间并加密上传 |
| 5 | **威胁报告含路径**：`hitFiles` 可能暴露用户文件路径 |
| 6 | **风险提示页同屏广告**：高风险警告下方同时展示第三方应用推荐 |
| 7 | **无用户可见提示**：没有告知上传范围、云端取片或威胁报告 |
| 8 | **shell 安装绕过上报**：`adb install`/`pm install` 不触发 UI 上报，说明上报绑定安装器 UI，而非安装本身 |

### 9.6 建议

**用户侧**

- 安装敏感 APK 时优先使用隔离环境/备用机；
- 不要在来源不明的 APK 上直接点“安装”或“取消”，两者都会触发 `/avl/upload`；
- root 防火墙限制 `com.miui.packageinstaller` 联网会影响云查/广告等在线功能，且未验证对安装成功率的影响，不能视为可靠缓解。

**厂商侧**

- 取消安装时停止 `/avl/upload`；
- 安装前明确告知上传字段并提供拒绝选项；
- 最小化设备标识与安装元数据；
- APK 片段/TLSH 上传改为单独授权，默认关闭；
- 威胁报告的 `hitFiles` 做路径脱敏；

- 风险提示页不要展示广告；
- 提供上报记录查看与删除入口。

### 9.7 证据

- 代码路径：`I.java`、`util/a.java`、`C0647e.java`、`c0.java`、`C0609a.java`、`ScanRequestArgs.java`、`F1/e.java`、`F1/t.java`、`E1/A.java`、`ReportWorker.java`；3.1.4 对应 `bx.java`、`rd2.java`、`ec2.java`、`s82.java`；
- 请求：`/v3/cloud_config/query`、`/v4/game/interceptcheck/safemode`、`/avl/upload`、`/risk/scan`；
- 日志标签：`MIUIPI_NetUtil`、`MIUIPI_InstallDataReporter`、`MIUIPI_NewVirusScanner`、`VirusScanManagerService`、`CloudScanner`、`MIUIPI_InstallProgress`；
- 脱敏证据：`evidence/redacted/package_installer_upload.log`、`evidence/redacted/cloud_config_global_summary.md`；
- 原始 pcap 仅在本地 `private/pcap/`；完整云控响应仅在 `private/frida/`，不入库。

## 10. 安全与合规问题

1. **明文 HTTP 传输元数据**：请求走 `http://`，URL、机型、厂商、时间、大小、`sign` 可被中间人观察。
2. **弱加密设计**：AES-128-ECB、无 IV、`key = MD5(明文)`，确定性加密；相同明文产生相同密文。
3. **1024 位 RSA + 100 年有效期**：自签名证书，2019–2119；结构正常（popcount 49.7%，无小因子、无共享素数、无近似素数），但 1024 位已低于现代标准。该证书用于内置密钥封装，不等同于已证明参与 TLS 校验的证书；公钥加密本身也不提供客户端身份认证。
4. **导出组件的潜在未授权调用面**：静态检查未见调用方校验；普通第三方应用能否实际修改 `SystemHelper` 上报服务器、触发上报或启动移动 DM，仍需最小 PoC 验证。
5. **可观测性缺失**：两套 DM 均无用户可见开关/日志；对联通 DM 而言，`operator_service_improve_plan` 是唯一总闸；移动 DM 由云端开关单独控制。
6. **加密可逆性（仅限匹配明文）**：由于 key 由明文派生，能获取对应本地明文（root、备份、队列）的一方可以还原该条流量；不能据此解密没有匹配明文的未知流量。
7. **电信自动注册组件**：路径 B 使用明文 HTTP（MAC/IP/BSSID/CTEI）；`AutoRegReceiver` / `RegistrationService` 导出且未见调用方校验（静态，普通应用实际可达性待 PoC）；`zzhc` 载荷仅为 Base64。

8. **包管理器取消也上报**：用户未安装，`/avl/upload` 仍上传包名、应用名、版本、签名、APK MD5、大小、权限与来源。
9. **打开安装界面即上报**：尚未确认安装，安装器已向 `api.installer.xiaomi.com` 发送包名、应用名、OAID、机型、区域等信息。
10. **云端可控取片**：`cInfo.cOffset/cSize` 由服务器决定，可读取 APK 任意区间并 AES-CBC 加密上传；`tFlag` 触发 TLSH 模糊哈希。
11. **威胁报告含路径**：GuardProvider 命中威胁后上报的 `hitFiles` 可能包含用户文件路径。
12. **风险应用取消也上报**：在“发现风险”页取消后，仍上传包名、应用名、版本、APK MD5、签名、大小、全部权限与来源。
13. **风险提示页同屏广告**：高风险警告下方同时展示第三方应用推荐广告，容易分散用户对风险的注意。
14. **分析埋点包含风险结果**：`request_result=virus`、`risk_app_type=9999`、`app_local_scene=virus_engine` 出现在安装器 OneTrack 分析事件中；本次窗口内未观察到另一路威胁报告，不等于从未入队。

---

## 11. 隐私影响（定性）

可被还原的画像维度：

| 维度 | 内容 |
| --- | --- |
| 设备身份 | 设备标识、SIM 标识、机型、系统、存储 |
| 位置 | 经纬度、行政区、基站、WiFi、路由器公网 IP |
| 行为 | 每个 App 的使用时长、启动次数、流量 |
| 安装 | 安装来源、版本、安装时间、部分签名；包管理器另上报应用名、APK MD5/大小/权限、安装或取消 |
| 截屏 | 毫秒时间戳（仅本地） |
| Root/框架 | 可识别 root 与框架类工具 |

两套 App 清单合并后，可判断设备的 root 状态、常用应用、作息与位置轨迹。

---

## 12. 建议

### 12.1 用户侧（部分可逆）

> 删除数据库**不可逆**；`cmcc_dm.db` 含多张业务表，不只是待传队列。运行时删除数据库/WAL/SHM 还可能遇到打开句柄、重建和状态不一致。默认建议是**先停用并保留可恢复配置**，不要直接整库删除。

```
# 0) 先记录原开关值（在同一主机 shell 中保留变量，不上传到公开日志）
original_plan=$(adb shell settings get secure operator_service_improve_plan | tr -d '\r')
# 同时记录两个包原来的 enabled 状态；原来已停用的包，恢复时保持停用。
adb shell pm list packages -d --user 0 com.mobiletools.systemhelper
adb shell pm list packages -d --user 0 com.miui.dmregservice

# 1) 关闭联通 DM 的服务改进计划（不影响移动 DM）
adb shell settings put secure operator_service_improve_plan 0

# 2) 先停用组件，避免继续写入
adb shell su -c 'pm disable-user --user 0 com.mobiletools.systemhelper'
adb shell su -c 'pm disable-user --user 0 com.miui.dmregservice'

# 3) 如需清理，由熟悉 SQLite 的人员确认写入进程已停止后，
#    在受保护位置制作一致性快照，再受控导出/加密备份。
#    不默认整库删除，也不把含标识/位置的明文数据库复制到共享 Download。

# 4) 域名封堵：dm.wo.com.cn / a.fxltsbl.com / m.fxltsbl.com / auc.fxltsbl.com

# 5) 恢复前核对记录：只恢复原先启用的组件，原先停用的保持停用。
#    示例（仅适用于原先启用的包）：adb shell pm enable --user 0 <包名>
#    开关按 original_plan 原值恢复；原先输出 null 表示键不存在，应 delete。
#    original_plan 必须来自步骤 0；若变量丢失，停止并查记录，不猜测为 1。
#    case "$original_plan" in
#      null) adb shell settings delete secure operator_service_improve_plan ;;
#      0|1) adb shell settings put secure operator_service_improve_plan "$original_plan" ;;
#      *) echo '原值缺失或不属于预期范围，请人工核对，不自动恢复' ;;
```

```
#    esac


# 6) 包管理器目前无公开上报开关；敏感 APK 优先隔离环境/备用机。
#    限制 com.miui.packageinstaller 联网会影响云查/广告，且未验证安装成功率。
```

### 12.2 厂商/运营商侧

- DM 通道改为 HTTPS，或至少使用 AEAD（AES-GCM）与随机 IV；
- 停止使用 `key = MD5(明文)`，改为标准密钥协商；
- 升级到 ≥2048 位 RSA 并缩短证书有效期；
- 为导出组件增加 signature 权限与调用方校验；
- 提供用户可见的开关、数据清单与删除入口；
- 明确告知预装 DM 客户端的存在与采集范围。
- 包管理器取消安装时停止 `/avl/upload`；安装前明确告知字段并提供拒绝选项；
- 默认关闭 APK 片段/TLSH 上传，改为单独授权；
- 威胁报告的 `hitFiles` 做路径脱敏，并提供上报记录查看/删除入口。

---

## 13. 附录：IOC

**域名 / IP**

```
dm.wo.com.cn:18080            → 223.111.128.82 (CNAME 63ce5fd2be92dcdf.icloudv6.com)
a.fxltsbl.com:443             → 117.134.71.39
b.fxltsbl.com:443
m.fxltsbl.com:5683            → 117.134.71.81 (CoAP)
auc.fxltsbl.com:443
event-log.cnbj1.mi-fds.com:443
zzhc.vnet.cn:443
typdm.tydevice.com:80
api.installer.xiaomi.com:443   → /v3/cloud_config/query、/v4/game/interceptcheck/safemode、/info/layout/v2、/avl/
upload
virus-engine.sec.miui.com:443  → /risk/scan（3.1.4；2.5.6 为 /virus/scan）、/virus/localResult/report
```

```
t1.a.market.xiaomi.com:443     → 安装器广告/推荐资源
t5.a.market.xiaomi.com:443     → 安装器广告/推荐资源
```

**包名 / 路径**

```
com.mobiletools.systemhelper   /system/priv-app/SystemHelper/SystemHelper.apk
com.miui.dmregservice          /product/priv-app/RegService/RegService.apk
com.miui.misightservice        /system_ext/app/MiSightService
com.miui.securitycenter        /data/misc/user/0/securitycenter/fraud_detection_data.db
com.miui.guardprovider         /product/app/MIUIGuardProvider
com.xiaomi.registration        /product/priv-app/AutoRegistration/AutoRegistration.apk
com.miui.packageinstaller      /data/app/.../com.miui.packageinstaller-.../base.apk（系统应用更新）
```

**核查命令**

```
adb shell pm path com.mobiletools.systemhelper
adb shell dumpsys package com.mobiletools.systemhelper | grep -E "versionName|appId|codePath"
adb shell settings get secure operator_service_improve_plan
adb shell su -c 'sqlite3 /data/user/0/com.mobiletools.systemhelper/databases/systemhelper \
  "select ID, length(jsonString) from dmregister"'
adb shell ss -tnp | grep -E "18080|:443"
adb shell dumpsys package com.miui.packageinstaller | grep -E "versionName|versionCode"
adb logcat -d | grep -E "MIUIPI_NetUtil|MIUIPI_InstallDataReporter|MIUIPI_NewVirusScanner|VirusScanManagerService|
CloudScanner|RealScanner"
```

---

## 13.1 证据包

完整证据随报告仓库提供：

```
evidence/
├──── MANIFEST.md                # 每个文件的 SHA-256
├──── SHA256SUMS                 # 可直接 sha256sum -c 校验
├──── apk/                       # 6 个 APK（本地保留，不入库）
├──── decompiled/
|    ├──── key/                   # 83 个 Java + 2 个转储/伪代码 + 1 个 Manifest（86 个文件）
|    └──── full/                  # 完整 jadx 源码树（本地保留）
```

```
├── certificates/              # pub.cer / pub.pem / openssl 文本
├── databases/                 # 仅 schema 与行数
└── redacted/                  # 脱敏样本与日志
```

> 原始 pcap 仅本地保留（`private/pcap/`），不入库。

校验：

```
sha256sum -c evidence/SHA256SUMS
```

> 原始数据库、解密后的 CSV/JSON、含隐私的内部报告均在 `private/`，不随公开仓库分发。

---

## 14. 限制与声明

- 本报告基于单台设备、单次取证，不代表所有小米机型/系统版本。
- 反编译代码可能因混淆存在偏差；关键结论尽量通过运行时数据与抓包交叉验证，无法实测的已在正文标注。
- 取证过程未修改业务逻辑；测试用配置已恢复原值。
- 本文已移除设备标识、SIM 标识、位置、WiFi、App 清单等个人隐私信息，仅保留技术事实。
- 文中所述组件均为系统预装、Xiaomi 平台签名，不代表其具有恶意意图；报告关注的是采集范围、加密方式与用户可控性。
- 包管理器部分基于单台设备、多次安装/取消测试；未使用真实诈骗样本，但使用了一个被 Avl 标记的色情风险样本；用户完成单次授权后安装成功，`/avl/upload` 为 `installCnt=1`。测试窗口内未观察到 `/virus/localResult/report` 或 `cToken/tInfo`；事后空目录不能排除曾入队后上传/删除。本次两条 shell 安装路径未进入 UI，窗口内未观察到同一 `/avl/upload`，不推广为所有后台或延迟链路均无上报；其他 session/企业安装路径未覆盖。